Quatro alertas.
Uma dependência corrigida.

A investigação confirmou três alertas altos e um moderado em cryptography 47.0.0. A dependência Python foi atualizada para 50.0.2. A auditoria npm do vídeo não cobre essa biblioteca.

O que foi analisado

Foram consultados os alertas autenticados do repositório, os avisos oficiais e o histórico da biblioteca. O código usa Fernet para proteger chaves de IA e identificações locais. Não foram encontradas chamadas diretas às APIs de certificados e PKCS#7 citadas nos alertas; isso não elimina a necessidade da atualização.

Alerta / problema	Gravidade	Correção mínima
m2h6-j472-rp4c / nomes DNS	Moderada	49.0.0
jwv3-5hgf-82ww / cadeias de certificados	Alta	49.0.0
g6cj-pr64-35w5 / PKCS#7	Alta	50.0.0
537c-gmf6-5ccf / OpenSSL	Alta	48.0.1

Decisão e alterações

requirements.txt agora permite versões a partir de 50.0.2 e inferiores a 51; requirements-lock.txt fixa 50.0.2. Atualizar somente até 49 deixaria um alerta sem correção. A atualização pontual reduz o risco de mudanças colaterais. Nenhuma chave real foi substituída. Commit da correção: 33eaa43.

Testes efetivamente executados

181 testes aprovados, com seis avisos de depreciação. pip check não encontrou incompatibilidades. Dois testes novos abriram tokens sintéticos criados antes da atualização, com a versão 47.0.0, usando chave por arquivo e por ambiente. Também verificaram nova cifragem, rejeição de chave incorreta e preservação da chave. Runtime: Python 3.12.0 / Windows 64 bits; OpenSSL 4.0.3.

Conferência no GitHub

Correção enviada ao GitHub privado. Na última consulta, os quatro alertas ainda estavam abertos, aguardando confirmação do reprocessamento automático. Consulta UTC: 2026-10-23T23:56:45.874009+00:00.

Limites e aprendizado

Esta revisão não é um pentest nem uma auditoria completa do sistema. Outros ambientes precisam instalar o lock atualizado e reiniciar seus processos. Os avisos de testes não foram ocultados. A série nova deixou de suportar Windows 32 bits e wheels macOS Intel. Não foram usados clientes reais ou chamadas pagas.

Para estudar: o vetor antigo testa compatibilidade histórica; cifrar e decifrar apenas com a versão nova não provaria isso. Desafio: teste a rejeição de um token sintético com um byte alterado.

Fontes: histórico oficial cryptography e GitHub Advisory Database (IDs na tabela). Detalhes, links diretos e evidências: docs/SECURITY-DEPENDENCIES-2026-10-23.md.